

Sistema de Gestión de Seguridad de la Información (SGSI)

Basado en ISO/IEC 27001

1. Introducción

Este documento describe el Sistema de Gestión de Seguridad de la Información (SGSI) implementado para una empresa que dispone de una infraestructura básica compuesta por:

- Conexión a Internet
- Router corporativo
- Firewall ASA
- Switch de comunicaciones
- Equipos de usuario
- Servidor corporativo

El objetivo principal es proteger la confidencialidad, integridad y disponibilidad de la información mediante controles alineados con la norma ISO/IEC 27001.

2. Objetivo del SGSI

El objetivo del SGSI es establecer medidas organizativas, técnicas y operativas para:

- Proteger la información corporativa.
 - Reducir riesgos de ciberseguridad.
 - Garantizar la continuidad operativa.
 - Minimizar accesos no autorizados.
 - Controlar amenazas internas y externas.
 - Cumplir buenas prácticas de seguridad.
-

3. Alcance

El alcance del SGSI incluye:

- Red corporativa interna.

- Servidor empresarial.
- Equipos de empleados.
- Firewall perimetral.
- Router corporativo.
- Switch principal.
- Servicios internos de red.
- Acceso a Internet.

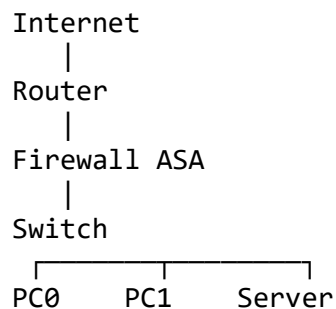
Quedan fuera del alcance:

- Dispositivos personales de empleados.
 - Servicios cloud externos no gestionados por la empresa.
-

4. Contexto de la organización

La empresa utiliza una arquitectura de red segmentada con protección perimetral mediante firewall ASA.

La infraestructura implementada en Packet Tracer sigue un modelo de defensa en profundidad:



La red interna utiliza direccionamiento privado y políticas de acceso restringido.

5. Política de Seguridad de la Información

La organización establece las siguientes políticas:

1. Todo acceso a la red debe estar autorizado.
2. Los usuarios tendrán únicamente los permisos necesarios.
3. Los servicios inseguros quedarán deshabilitados.
4. El tráfico será filtrado mediante firewall.

5. Las contraseñas deberán ser robustas.
6. Se aplicarán actualizaciones periódicas.
7. Se monitorizarán eventos de seguridad.
8. Se realizarán copias de seguridad periódicas.
9. Se limitará la exposición de servicios a Internet.
10. Todo incidente de seguridad deberá ser reportado.

6. Inventario de activos

Activo	Descripción	Criticidad
Servidor corporativo	Servicios internos y almacenamiento	Alta
PCs empleados	Equipos de trabajo	Media
Firewall ASA	Protección perimetral	Alta
Router	Comunicación con Internet	Alta
Switch	Conectividad interna	Media
Información corporativa	Datos internos y documentación	Alta

7. Evaluación de riesgos

Riesgo	Impacto	Probabilidad	Nivel
Acceso no autorizado	Alto	Medio	Alto
Malware	Alto	Medio	Alto
Ataques externos	Alto	Medio	Alto
Robo de información	Alto	Bajo	Medio
Fallo del servidor	Alto	Bajo	Medio
Uso de protocolos inseguros	Alto	Medio	Alto
Errores humanos	Medio	Alto	Alto

8. Tratamiento de riesgos

Medidas implementadas

Medida	Objetivo
Firewall ASA	Filtrado de tráfico
ACLs	Restricción de acceso

Medida	Objetivo
Segmentación lógica	Separación de recursos
Direccionamiento privado	Protección de red interna
SSH y HTTPS	Comunicaciones cifradas
Deshabilitación de Telnet y FTP	Eliminación de protocolos inseguros
Monitorización de red	Detección de incidentes
Copias de seguridad	Recuperación ante fallos
Actualizaciones periódicas	Reducción de vulnerabilidades

9. Arquitectura de seguridad implementada

Segmentación de red

Red interna usuarios

- VLAN lógica interna
- Rango: 192.168.10.0/24

Firewall

- Interfaz outside: 192.168.1.2
- Interfaz inside: 192.168.10.1

Router

- Conectividad con Internet
- Traducción y encaminamiento de tráfico

10. Controles ISO 27001 aplicados

Dominio ISO 27001	Implementación
Control de acceso	ACLs y segmentación
Seguridad de red	Firewall ASA
Gestión de vulnerabilidades	Actualizaciones periódicas
Protección de activos	Restricción de servicios
Gestión de incidentes	Monitorización y respuesta
Seguridad operacional	Configuración segura
Continuidad del negocio	Backups y recuperación
Gestión de riesgos	Evaluación y mitigación

11. Gestión de accesos

Usuarios

Los usuarios tendrán acceso únicamente a los recursos necesarios para su trabajo.

Administradores

Los administradores dispondrán de permisos elevados únicamente para tareas técnicas.

Autenticación

- Uso obligatorio de contraseñas robustas.
 - Renovación periódica de credenciales.
 - Restricción de acceso remoto.
-

12. Seguridad perimetral

La empresa implementa un firewall ASA como elemento principal de protección.

Funciones del firewall

- Filtrado de tráfico.
 - Bloqueo de conexiones no autorizadas.
 - Separación entre Internet y LAN.
 - Aplicación de ACLs.
 - Protección del servidor corporativo.
-

13. Monitorización y auditoría

Se establecerán mecanismos de supervisión para:

- Detectar accesos sospechosos.
 - Revisar logs de seguridad.
 - Identificar intentos de intrusión.
 - Supervisar actividad del firewall.
 - Verificar disponibilidad de servicios.
-

14. Gestión de incidentes

En caso de incidente de seguridad:

1. Identificar el incidente.
 2. Contener el problema.
 3. Analizar el impacto.
 4. Recuperar los sistemas afectados.
 5. Documentar el incidente.
 6. Aplicar medidas correctivas.
-

15. Copias de seguridad

La organización realizará:

- Copias periódicas del servidor.
 - Verificación de integridad de backups.
 - Almacenamiento seguro de copias.
 - Procedimientos de restauración.
-

16. Mejora continua

El SGSI será revisado periódicamente para:

- Identificar nuevas amenazas.
 - Corregir vulnerabilidades.
 - Actualizar políticas.
 - Mejorar controles de seguridad.
 - Adaptarse a nuevos riesgos tecnológicos.
-

17. Conclusión

La implementación de este SGSI permite reducir significativamente los riesgos de seguridad mediante controles técnicos y organizativos alineados con ISO/IEC 27001.

La arquitectura implantada proporciona:

- Protección perimetral.

- Segmentación de red.
- Control de accesos.
- Mitigación de amenazas.
- Seguridad operacional.
- Capacidad de monitorización.

El sistema diseñado cumple con los principios fundamentales de confidencialidad, integridad y disponibilidad de la información.